

Day 17 – RDP Detection Engineering

Remote Desktop Protocol (RDP) Fundamentals

Remote Desktop Protocol (RDP) is Microsoft's remote access protocol that enables users and administrators to securely connect to Windows systems over a network. It is widely used for remote administration, server management, IT support, and remote work. Because RDP provides interactive access to systems, it is also one of the most frequently targeted services by attackers.

Legitimate Administrator Use Cases

- Remote server administration
- IT helpdesk and troubleshooting
- System maintenance
- Remote workforce access
- Secure management through jump servers

Common Attacker Abuse

Attackers commonly exploit exposed or weakly protected RDP services to gain unauthorized access.

Typical attack techniques include:

- Password brute-force attacks
- Credential stuffing using leaked passwords
- Login using stolen or valid credentials
- Lateral movement between systems
- Privilege escalation
- Ransomware deployment after gaining remote access

Detection Engineering for RDP

Effective RDP detections should focus on **authentication behavior**, **login context**, and **post-authentication activity** instead of relying solely on successful RDP logins.

Primary Detection Opportunities

Detection	Suspicious Behavior
RDP Brute Force	Multiple failed logins from the same IP within a short time
Successful Login After Failures	Numerous Event ID 4625 events followed by Event ID 4624
Unusual RDP Login	Login from a new IP, country, or outside business hours
Privileged Account Login	Administrator or Domain Admin RDP session

Detection

Suspicious Behavior

Post-RDP Activity

PowerShell, account creation, Scheduled Tasks, or outbound network traffic after login

Primary telemetry includes **Windows Event IDs 4624, 4625, 4778, 4779, 1149, Sysmon Process Creation, Microsoft Defender XDR DeviceLogonEvents, Firewall logs, VPN logs, and EDR telemetry.**

Detection Tuning

Generating alerts for every RDP login quickly overwhelms SOC analysts and produces excessive false positives. Effective tuning improves detection quality by incorporating user behavior, authentication context, and event correlation.

Recommended Tuning

- Allowlist approved administrators, jump servers, and management systems.
- Exclude scheduled maintenance windows.
- Establish baselines for normal login times, source IP addresses, and devices.
- Correlate VPN authentication with subsequent RDP sessions.
- Prioritize privileged account logins from unfamiliar locations.
- Increase severity only when RDP is followed by suspicious activities such as PowerShell execution, account creation, persistence, or external network communication.

Behavioral correlation significantly improves detection fidelity compared to isolated authentication alerts.

Practical Exercise Findings

- Studied legitimate RDP administration and the ways attackers abuse RDP for initial access, credential compromise, lateral movement, and ransomware deployment.
 - Created detection logic for RDP brute-force attacks, successful logins following repeated failures, unusual login times, unfamiliar source IPs, privileged account access, and RDP sessions followed by PowerShell execution.
 - Developed five detection rules covering authentication anomalies, privileged access, behavioral correlation, and post-login activity, including detection logic, telemetry sources, MITRE ATT&CK mapping, severity, and tuning guidance.
 - Tuned RDP detections by introducing administrator allowlists, jump server exclusions, baseline login behavior, VPN correlation, and multi-event analysis to reduce false positives while maintaining visibility into genuine attacks.
-

Investigation Scenario

The investigation correlated multiple detections into a complete attack sequence. An external IP (**203.0.113.25**) performed repeated RDP brute-force attempts before successfully authenticating as the **Administrator** account. Shortly afterward, **PowerShell** executed, a **new local administrator account** was created, an **outbound HTTPS connection** was established, and a **Scheduled Task** was created to maintain persistence. The correlated evidence strongly indicated an active compromise consistent with hands-on-keyboard intrusion or ransomware activity. The incident was classified as **Critical**, with recommendations to isolate the affected system, reset privileged credentials, preserve forensic evidence, block attacker infrastructure, and conduct environment-wide threat hunting for lateral movement and persistence mechanisms.

MITRE ATT&CK

- **T1110** – Brute Force
 - **T1078** – Valid Accounts
 - **T1021.001** – Remote Services: Remote Desktop Protocol
 - **T1059.001** – PowerShell
 - **T1136** – Create Account
 - **T1547.001** – Registry Run Keys / Startup Folder (*general persistence awareness*)
 - **T1053.005** – Scheduled Task/Job
 - **T1071.001** – Application Layer Protocol (Web Protocols)
-

Key Takeaway

RDP is a legitimate remote administration protocol but also one of the most common entry points for attackers. High-fidelity RDP detections should combine authentication anomalies with contextual and post-login behaviors such as PowerShell execution, account creation, persistence mechanisms, and outbound network activity. Correlating multiple telemetry sources and continuously tuning detection rules significantly improves alert quality, reduces false positives, and enables earlier detection of ransomware and interactive intrusions.